SENTINEL

Runtime trust for AI agents

Product dossier: what it does, how it is built, how to set it up and run it, what is proven, and where it stands against the alternatives.

Status	Invite-only developer preview. Demonstrated on one cloud host. No customer in production.
Date / commit	4 October 2026 | f36ca59 (branch program/production-readiness)
Live read-only demo	http://sentinel-proof-557842222.ap-south-1.elb.amazonaws.com/console
Windows download	https://sentinel-downloads-024330900387.s3.ap-south-1.amazonaws.com/downloads/windows/Sentinel-AI-Scan-Windows.exe
Evidence	4,567 automated tests, 0 failures, on SQLite and PostgreSQL; 18 CI jobs green on main

How to read this document. Every capability here is tagged with how far it has been proven. The words *production-ready, secure, compliant* and *market-leading* do not appear as claims, because the evidence for them does not exist yet. Where Sentinel is behind an alternative, this document says so in the same table that says where it is ahead.

1. What Sentinel does

AI agents no longer only answer questions; they change things: they deploy code, edit infrastructure, move money, send messages. Sentinel is the checkpoint between an agent and the change. Before an agent's tool call takes effect, Sentinel decides one of four things, by fixed rules rather than by a model's opinion:

Decision	Meaning	What happens next
allow	Policy permits the action	The agent proceeds; an authorization is issued that commits to the exact parameters
warn	Permitted, but noteworthy	Proceeds and is recorded for review
require_approval	A person must decide	A request appears in the console with a countdown; nothing runs until someone with the right role approves
block	Policy refuses	The action does not run; an incident may be raised

Around that decision Sentinel does six further jobs:

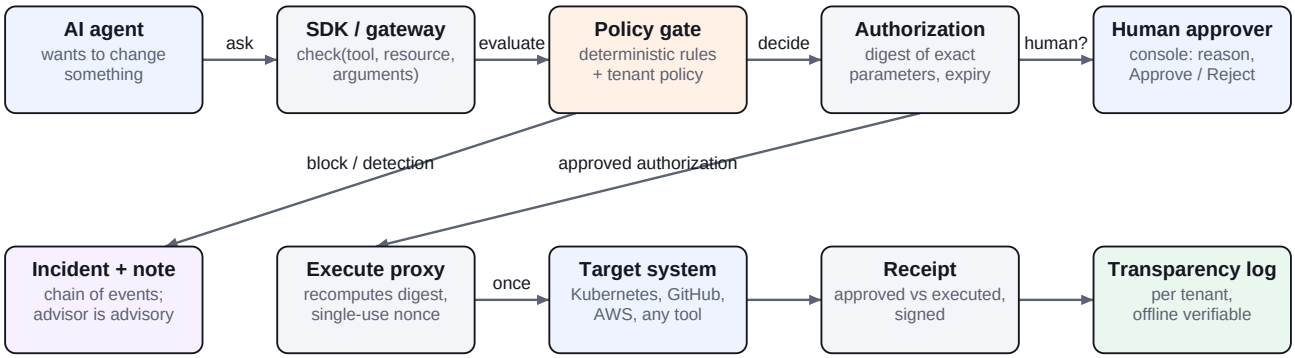
- **Binds the approval to the execution.** An approval commits to a digest of the exact tool, resource and arguments. Different arguments are refused; the same approval cannot run twice.
- **Records proof.** Each execution produces a receipt stating what was approved and what ran. Receipts are committed to a per-tenant transparency log and can be verified offline.
- **Detects suspicious chains.** Events from agents are assembled into incidents (for example: read a file, compress it, post it to an outside host) with the causal chain shown.
- **Contains an agent.** An analyst can pause one agent, with a reason and an expiry; its calls are refused until the containment ends.
- **Inventories AI tools.** A consent-based scanner (command line or a double-click app for macOS and Windows) lists which AI tools are installed on a device.
- **Adds an advisory second opinion.** A model (the owner's Antigravity CLI running Gemini) writes a note for the analyst on each incident. It is labelled unverified and cannot change any decision.

What Sentinel is not

- It is **not** a SOC or a general AI-security scanner. It governs agent actions; it does not hunt malware or watch a network.
- It does **not** stop an agent that bypasses it. It controls calls routed through it (SDK, tool gateway, MCP proxy). Closing the bypass is a deployment task: credentials the agent does not hold, and network or API-server rules.
- It does **not** let a model decide. Decisions are deterministic policy. Remove the advisor and every decision is identical.
- The device scanner sees **presence only**: that a file, app or command with a known name exists. It opens nothing, runs nothing and sends nothing.

2. How a protected action flows

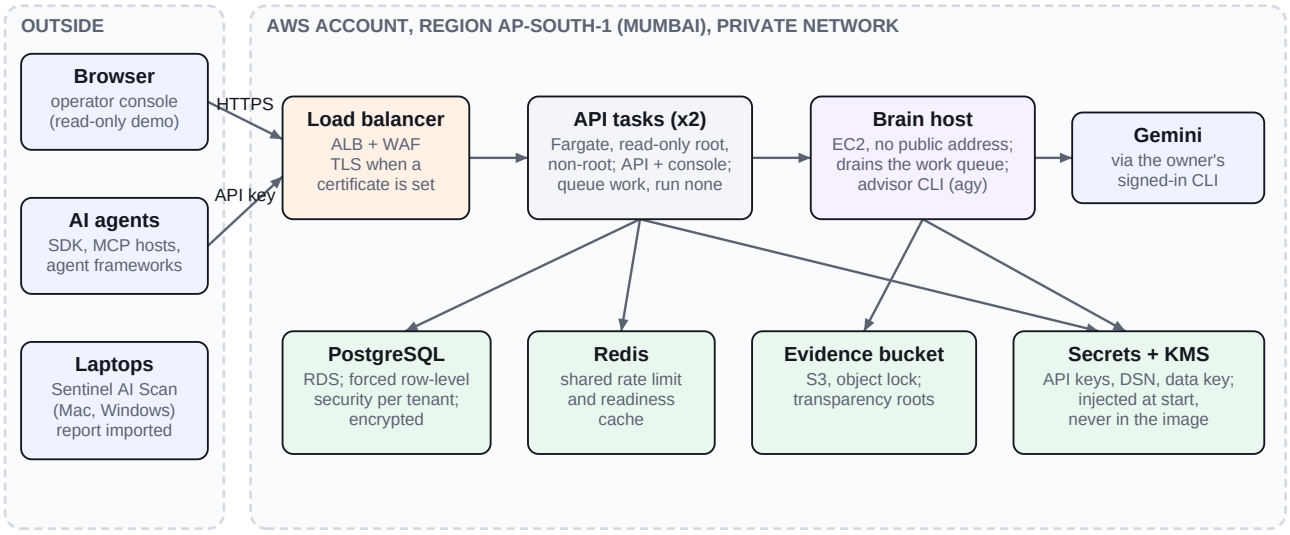
The diagram shows the path of one consequential action, from the agent's request to the proof that it happened as approved.



Step	What happens	What is refused
1. Ask	The agent (through the SDK, the tool gateway or the MCP proxy) asks before acting.	A caller with no valid key gets no decision at all (401), never an allow.
2. Decide	Rules are evaluated on the tool, resource and the actual arguments. Trust comes from how the caller authenticated, not from what it claims.	A request that asserts its own trust level is rejected.
3. Authorize	On allow or require_approval an authorization is stored, bound to tenant, agent, tool, action, resource, parameter digest, policy version, expiry and a single-use nonce.	An approval for one tenant, agent or policy version cannot be used for another.
4. Approve	A person with the decide role reads why approval is needed, types a reason and approves. A quorum and requester/approver separation can be required.	An expired request (about five minutes) cannot be approved; the agent must ask again.
5. Execute	The proxy recomputes the parameter digest immediately before the tool runs.	Changed arguments, a second use, or execution before approval: all 403.
6. Prove	A receipt records the binding. If the target's answer is lost, the operation is marked unknown and reconciled from the target, not repeated.	A receipt is never silently rewritten; the log is append-only.

3. Architecture

3.1 Deployed architecture (the AWS environment behind the live demo)



Two API tasks answer every request and serve the console. They run **no** incident pipeline. One separate host, reachable only through AWS Session Manager, runs the same image as the pipeline worker with the advisor CLI mounted read-only. The database enforces tenant isolation itself: every tenant table has forced row-level security, so a query without a tenant context returns nothing.

3.2 Code architecture

The service is one Python package arranged as ports and adapters. Dependencies point inward only; an architecture test fails the build if a layer imports the wrong way, if any module exceeds 800 lines, or if anything outside the settings module reads the environment.

Layer	Files	Responsibility	May depend on
domain	53	Incidents, authorizations, policy, severity, state machines. Pure logic, no I/O.	nothing
application	30	Use cases: admit an event, evaluate, decide an approval, run the pipeline, queries. Defines ports.	domain
infrastructure	108	Adapters: SQL (SQLite and PostgreSQL), outbound HTTP hardening, evidence, transparency, SIEM/SOAR, identity, advisor.	application, domain
interface	29	HTTP routes, console, CLI, workers, rate limiting.	application
composition	18	Settings (170 documented variables), container wiring, production preflight.	all, at the edge
sdk	14	Client, framework adapters, MCP stdio bridge, device scanner and desktop app (standard library only).	nothing server-side

3.3 Data and state

Store	Holds	Protection
PostgreSQL (schema version 38)	Incidents, authorizations, approvals, receipts, policy versions, audit trail, work queue, device inventory	Forced row-level security; the service connects as a non-superuser; migrations are a separate deployment step and the service refuses to start on an old schema
Transparency log	One append-only Merkle log per tenant committing each receipt	Never reaped; consistency proofs; roots can be published to object-locked storage
Evidence bodies	The detail behind each incident and approval	Sealed per record under a data key; losing the key loses bodies, never proofs
Redis	Rate-limit counters, readiness cache	The service refuses to run more than one process in production without it
Secrets Manager	API keys, database URL, data key, demo key	Injected at task start; not visible in the task definition

4. Every component, small to large

Tier is the strongest evidence that exists for the component: **integration** = passed on PostgreSQL as well as SQLite; **unit** = passed in tests only; **live** = additionally exercised on the AWS environment or a real machine. No component has production or independent-assessment evidence.

Component	What it does	Proven to	Honest limit
Policy gate	Deterministic rules plus a tenant policy that can only tighten the baseline	unit; live	Rules are curated; no outside evaluation of what they miss
Execution binding	Authorization bound to tenant, agent, tool, action, resource, parameter digest, policy digest, expiry, nonce	integration; live	Bypass prevention needs the agent to hold no direct credential
Approvals	Redacted change view, quorum, separation of duties, stale-approval refusal, expiry	integration; live	Console and API only; no mobile or chat approval
Execution proxy + receipts	Runs the tool once under the approval and records approved-versus-executed	integration; live	Commitment to the log is asynchronous
Durable outcomes	A lost response becomes an unknown operation that is reconciled from the target, not retried blindly	integration	Automatic for Kubernetes, GitHub contents and brokered AWS only
Transparency + passport	Per-tenant Merkle log; exported bundle verifies offline with the standard library	integration	No root is yet held outside the environment
Incident pipeline	Admits events, builds causal chains, triage by severity, evidence, report	integration; live	Detection corpus is curated, not blind-tested
Advisor	Model note on each incident via HTTP endpoint or the signed-in Antigravity CLI; sandboxed, no secrets inherited	unit; live (one host)	Runs on one personal Google account; 10-60 s per note; unmeasured under load
Containment	Pause an agent, tool or session with reason and expiry	integration; live	Only stops calls that pass through Sentinel
MCP tool gateway	Pins tool definitions, detects drift, proxies tools/call under policy	integration	Off on the AWS environment; streaming limited; not run against third-party servers
A2A gateway	Agent-card registry and proxy for agent-to-agent calls	integration	No real partner agent exercised
Workload identity	Verifies SPIFFE JWT-SVIDs and pod-bound Kubernetes tokens; can refuse API keys for agents	integration	Consumes identities; does not issue or rotate them
Credential broker	Per-operation short-lived credentials (Kubernetes TokenRequest, AWS STS, GitHub App)	integration	Only the Kubernetes path has met its real service
Coverage model	Counts observed, routed and enforced traffic separately; refuses to invent a percentage	integration	Bypass signals need the endpoint sensor deployed
Budget + circuit breaker	Shared, tenant-scoped limits that fail closed	integration	Not load-tested beyond two pools
Tenant isolation	Row-level security on PostgreSQL; explicit predicates on SQLite	integration; live	Per-pod aggregation and soak unverified
SIEM / SOAR export	Syslog, OTLP, webhook; ServiceNow, Jira, PagerDuty, Slack, Teams connectors	unit	No real tenant has consumed it; no vendor certification
Retention sweep	Reaps operational rows per tenant; evidence and receipts are append-only by declaration	integration	
Console	13 views: pilot setup, overview, agent requests, approvals, execution graph, approved vs executed, MCP estate, containment, policy, transparency, agents, supply chain, governance	live	Operator sign-in refused over plain HTTP by design

Component	What it does	Proven to	Honest limit
Python SDK + adapters	check / execute client; adapters for OpenAI Agents, Anthropic, Gemini, LangChain	live journey (client)	Adapters not run against their real frameworks
Device scanner	Presence of 18 AI tools across config files, apps and commands; consent per category	live (macOS); hosted Windows	No Windows PC with AI tools installed has been scanned
Desktop app	Double-click window over the scanner for macOS (universal) and Windows	window smoke on both	Unsigned: the OS warns on first open
Release hygiene	Allowlisted artifacts, secret scan, hash-pinned lock, clean-install smoke, signed-image option	unit; CI	Image signing unverified until publishing is enabled

5. Setting Sentinel up

There are three ways to run it today, in increasing effort. None is a production service.

5.1 Just the scanner (2 minutes, nothing to install)

Platform	Get it	Run it
Windows 10/11 (64-bit)	Download Sentinel-AI-Scan-Windows.exe from the link on the cover	Double-click. SmartScreen: More info, then Run anyway. Tick what you agree to check, Scan, Save report.
macOS (Apple Silicon or Intel)	Sentinel-AI-Scan-macOS.zip, sent by the owner	Unzip, right-click the app, Open, Open. Tick, Scan, Save report.
Any OS with Python 3.9+	sentinel-discover.py from the console (Pilot setup)	python3 sentinel-discover.py --consent --all --output me.json --html me.html

The saved .html page is the readable result; the .json file is what a Sentinel console imports. Nothing is sent anywhere by the scanner.

5.2 Your own Sentinel on a laptop (10 minutes)

Needs a copy of the repository and Python 3.12 or newer.

macOS / Linux

```
python3 -m venv .venv
.venv/bin/pip install -e ".[server]"
.venv/bin/python scripts/try_sentinel.py --scan --demo
```

Windows (PowerShell)

```
py -m venv .venv
.venv\Scripts\pip install -e ".[server]"
.venv\Scripts\python scripts\try_sentinel.py --scan --demo
```

That one command creates a private folder with a database and four fresh keys, prepares the database, scans the device, imports the result, loads a sample story and serves the console at **http://127.0.0.1:8000/console**. Paste the printed **admin key** as the operator token. To approve a request live: **Agent requests**, type a reason, **Approve**. For new waiting requests run the same script with `--fresh-requests` in a second terminal. Add `--advisor-cli ~/.local/bin/agy --advisor-model gemini-3.1-pro-high` to attach the advisor.

5.3 The cloud environment (what the live demo runs)

#	Step	Detail
1	AWS identity	A provisioning role that the operator assumes; credentials stay in an untracked .env
2	Build and push	Build the container image, push to the environment's registry, pin by digest
3	Apply the stack	OpenTofu (deploy/terraform/aws): network, load balancer + WAF, two API tasks, PostgreSQL, Redis, evidence storage, secrets, keys, alarms, budgets, backup
4	Set secrets	Tenant API keys (one per role), database URL, evidence data key; values are put by hand, never in code
5	Migrate	Run the schema migration as a one-off task. The service refuses to start on an old schema
6	Roll and verify	Roll the service; a rollout only counts when the running revision is the one requested
7	Brain host (optional)	Enable the brain host; connect through Session Manager; install the advisor CLI in /opt/agy; sign in once
8	HTTPS	A certificate for app.joinsentinelai.com is requested; two DNS records at the registrar complete it

5.4 Roles and keys

Role	Can	Cannot
ingest	Send events, ask for decisions, execute approved actions	Read incidents or approve
viewer	Read everything in the console	Change anything (the public demo key is this role)
analyst	Viewer, plus approve/reject requests and contain agents	Change policy or users
admin	Analyst, plus policy, users and device inventory imports	

"Operator token" in the console simply means one of these keys. The tenant is derived from the key, never from the request.

5.5 Settings that matter most

Setting	Effect
SENTINEL_PROTECT_ENFORCE, SENTINEL_PROTECTION_MODE	Whether a stop decision actually stops the action. Without them a verdict is advisory
SENTINEL_REQUIRE_EXECUTION_BINDING	Refuses any execution that does not present an authorization (on by default)
SENTINEL_API_KEYS	tenant:key:role entries. The only way callers are identified in the first workflow
SENTINEL_DATABASE_URL / SENTINEL_REDIS_URL	PostgreSQL and Redis. SQLite and a single process are refused in production
SENTINEL_DATA_KEY_<id>, SENTINEL_ACTIVE_KEY_ID	Seals evidence bodies. Production refuses to start without a key
SENTINEL_ADVISOR_CLI_COMMAND + _MODEL (or _ENDPOINT + _MODEL + _TOKEN)	Attaches the advisory model. All-or-nothing; absent means no advisor, stated in every record
SENTINEL_PIPELINE_WORKERS	Pipeline threads in this process; 0 makes an API-only replica
SENTINEL_CONSOLE_DEMO_TOKEN	Publishes a viewer key on the sign-in page; refused unless that key is viewer-only

6. What is proven, and what is not

Evidence	Result
Automated suite, both database engines, including a live Kubernetes contract test	4,567 tests, 0 failures, 0 errors, 38 skipped (commit 60b5109)
GitHub CI on main	All 18 jobs green: suite, live PostgreSQL/Redis, kind + Helm smoke, security, licences, image build, deployment manifests, release hygiene
Live AWS environment	Console, liveness, readiness 200; viewer refused a decision (403); no key refused (401); new incident carries the advisor note
Client SDK against a real server	Allow, require approval, refused before approval, approve, execute once, replay refused
Desktop app	Real window opened, ticked, scanned on macOS and on a hosted Windows machine
Local trial on Windows	Install, migrate, serve, scan, import, sample story: passed on a hosted Windows machine

Capability tiers (generated from the test evidence, not written by hand)

Tier	Count	Meaning
production_observed	0	Seen working for a real tenant
externally_verified	0	Independently assessed
integration_tested	12	Passed on PostgreSQL as well as SQLite
unit_tested	4	Passed in tests on these exact inputs

Open risks (from the risk register)

Id	Severity	Risk	State
R-001	critical	No production deployment has observed any control	open
R-002	high	No independent security assessment	open
R-003	high	Cross-region disaster recovery is unproven	open
R-004	high	Cloud topology applied on one host/region only	mitigated
R-005	medium	Detection metrics come from a curated corpus only	open
R-012	medium	Automatic reconciliation covers three target types; the rest needs a human	mitigated

Not tested in CI today: the live S3-compatible round-trip (the upstream MinIO image was withdrawn). Not done by anyone: a person using the Windows app on a PC with AI tools installed; code signing of either app; any run of the framework adapters against their real frameworks.

7. Sentinel and the alternatives

This comparison is built from each vendor's own public documentation, reviewed 17-20 September 2026. **No head-to-head test has been run.** "Not found in their documentation" means this review did not find it, not that the product lacks it. Read the "ahead" column as *what Sentinel can demonstrate on request*, and the "behind" column as fact.

7.1 Where Sentinel is ahead, and where it is behind

Area	Sentinel ahead (demonstrable today)	Sentinel behind (who leads, and why)
Exact-change binding	Approval commits to a digest of the exact parameters, policy version and a single-use nonce; changed arguments and replays are refused. Shown live.	AWS AgentCore documents parameter-level Cedar policies; the Agent Permission Protocol draft specifies signed scoped approvals. The idea is not unique.
Outcome after a lost response	An ambiguous execution becomes an unknown operation and is reconciled from the target without a second write (Kubernetes, GitHub contents, brokered AWS).	Only three target types. Nobody, including Sentinel, has shown this at a customer.
Proof that survives Sentinel	Receipts in a per-tenant transparency log; a bundle verifies offline with no Sentinel software.	No root is yet held outside the environment, and no restore from an independent failure domain has been done.
Honest coverage	Reports observed, routed and enforced traffic separately and refuses to turn them into one percentage.	Bypass detection depends on a sensor being deployed; network egress and non-Kubernetes targets are not covered.
Agent identity	Consumes SPIFFE and pod-bound Kubernetes identities; can refuse plain API keys for agents.	Microsoft Entra Agent ID, Auth0, Teleport and SPIRE issue, rotate and govern identities. Sentinel does not, and has not been integrated with any of them.
Credential brokering	Per-operation short-lived credentials for three targets.	Auth0 Token Vault, Pomerium and Teleport broker credentials for many upstreams, in production.
Approval experience	Redacted change view, quorum, separation of duties, expiry.	ITSM tools and Auth0 asynchronous authorization approve from phone, chat and tickets. Sentinel has a console and an API.
Gateway breadth	MCP proxy with pinned tool definitions and drift detection.	Kong AI Gateway and AWS AgentCore run managed gateways at measured scale with full streaming. Sentinel's proxy is off in its own demo.
Threat detection	Deterministic chain detection with the causal graph shown.	Palo Alto Prisma AIRS and Check Point / Lakera are dedicated detection products with independent evaluation. Sentinel has none.
Device inventory	Consent-based presence scan with a double-click app; opens and sends nothing.	Presence only. No visibility of browser or cloud AI, which endpoint and browser-security vendors cover.
Trust and distribution	Every claim is tiered by evidence; nothing is overstated.	Every funded competitor has customers, assessments, attestations, marketplaces and support. Sentinel has none of these.

7.2 Alternative by alternative

Alternative	What its documentation shows	Sentinel's honest position
AWS Bedrock AgentCore (Policy / Gateway)	Deterministic Cedar authorization at tool invocation, default deny; managed gateway; IAM/OAuth principals	An integration target. Sentinel must show added approval and outcome value before an AWS-only customer adds it
Microsoft Entra Agent ID	Agent identity lifecycle, ownership and governance	Integrate with it; Sentinel validates tokens but has no native Entra lifecycle integration
Auth0 for AI Agents	Authentication, Token Vault, asynchronous human authorization, fine-grained authorization	Human approval alone is not unique. Sentinel's case is precise scope plus independently observed outcome
Teleport	Short-lived cryptographic workload identities and infrastructure access	Integrate; Sentinel's attestation and credential issuance lack real-workflow evidence
Kong AI Gateway	MCP aggregation, routing, access policy, logging, rate limiting	Integrate rather than rebuild routing; Sentinel has not measured comparable interoperability or cost
Pomerium MCP gateway	Per-request policy, tool-level access, upstream OAuth and token delegation	Cannot claim unique delegated MCP access; compare the full protected-change workflow
Palo Alto Prisma AIRS	Runtime API/firewall, model security, red teaming, posture	No detection or red-team comparison exists; avoid any superiority claim
Check Point AI Guardrails / Lakera	Screens messages, tool interactions and tool descriptions through a Guard API	Evaluate as an advisory input; Sentinel's detector tests cannot establish better protection
Agent Permission Protocol (draft)	Execution-time policy verification, capability binding, signed approval receipts	Direct conceptual overlap; pursue interoperability and a narrower observed-outcome advantage
Customer-built (IdP + gateway + admission + SIEM)	Whatever the customer has assembled	Sentinel must beat their actual integration labour and investigation time, not a weak hypothetical

7.3 The unique selling proposition, stated carefully

No single feature has been shown to be absent from every alternative, and this document does not claim one. The proposition is the **combination, end to end, with honest failure handling**:

- **The exact change that was approved is the change that ran**, and a different or repeated one is refused at the last moment.
- **When the outcome is uncertain, Sentinel says so** and reconciles from the target instead of guessing or repeating.
- **The proof outlives Sentinel**: a receipt bundle that verifies offline.
- **It tells you where it is not protecting you**: observed, routed and enforced are counted separately.
- **A model never decides**: the advisor informs a human and holds no authority.

Each of these is a hypothesis until a customer trial compares it with what that customer uses today. The five acceptance tests for doing so are in USP_VALIDATION.md in the repository.

8. From preview to launch

An **invited developer preview** is ready today: chosen people get the demo link, the apps and the guide. A public launch is blocked by the items below, in order.

#	Gap	Why it blocks	Owner	Size
1	HTTPS on the console	Operators cannot sign in; browsers mark the page not secure. Certificate requested for app.joinsentinelai.com; two DNS records outstanding	Owner	An hour
2	Apps unsigned	macOS and Windows warn on first open	Owner: Apple Developer ID, Windows certificate	Days
3	Windows app on a real PC with AI tools	The folder list has only met a machine with none installed	Any Windows user	Minutes
4	Terms, privacy notice, sign-up, billing	Strangers running a scanner need a privacy notice; nobody can become a customer unaided	Owner	Days to weeks
5	Operations	One region, single-zone database, no on-call	Owner	Weeks
6	Outside evidence	No security assessment, no customer, no blind detection corpus	Owner + third parties	Weeks to months
7	Advisor on a personal account	Quota and continuity depend on one person's Google sign-in	Owner	Days

Where things are

Item	Location
Live demo (read-only)	http://sentinel-proof-557842222.ap-south-1.elb.amazonaws.com/console
Windows app, checksum, guide	https://sentinel-downloads-024330900387.s3.ap-south-1.amazonaws.com/downloads/windows/ (Sentinel-AI-Scan-Windows.exe, .sha256, README-Windows.txt)
Owner's demo runbook	docs/current/DEMO_RUNBOOK.md
Tester's guide	docs/current/TRY_SENTINEL.md
Evidence tiers / risks	docs/current/RELEASE_STATUS.md, RISK_REGISTER.md
Competitive sources	docs/current/COMPETITIVE_MATRIX.md (primary links, access dates)
Change history	docs/current/RELEASE_CHANGES.md

The accurate one-line description until items 1, 2 and 4 are done: **invite-only developer preview with tested execution control, demonstrated on one cloud host.**